



ARKA HEALTH, INC.

HIPAA PRIVACY POLICY

Uses and disclosures of Protected Health Information; business associate obligations; individual rights

ARKA-PRIV-001 · Version 1.0 · Confidential — Internal

Document No.	ARKA-PRIV-001
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE

This HIPAA Privacy Policy (this “**Policy**”) establishes the standards under which ARKA Health, Inc. (“**ARKA**” or the “**Company**”) and its Workforce Members may create, receive, maintain, use, disclose, and transmit Protected Health Information (“**PHI**”). It implements the requirements of the HIPAA Privacy Rule, 45 C.F.R. Part 164, Subpart E, as those requirements apply to ARKA in its capacity as a **business associate** of covered entities, and as such requirements are incorporated into each business associate agreement (“**BAA**”) to which ARKA is a party.

Capitalized terms used and not defined herein have the meanings assigned at 45 C.F.R. §§ 160.103 and 164.501 or in ARKA-GOV-001 (Information Security & Compliance Program Charter).

2. ARKA’S REGULATORY ROLE

2.1 Business associate posture

ARKA furnishes clinical decision-support and administrative-workflow software (the “**ARKA Platform**”) to health care providers, health plans, and other covered entities and business associates (each, a “**Customer**”). ARKA is not a covered entity. ARKA functions as a business associate within the meaning of 45 C.F.R. § 160.103 whenever it creates, receives, maintains, or transmits PHI on behalf of a Customer, and in certain deployments as a subcontractor business associate of another business associate. ARKA shall not create, receive, maintain, or transmit PHI for or on behalf of any Customer except pursuant to an executed BAA substantially in the form of ARKA-LGL-001 (or a Customer form approved by counsel).

2.2 No PHI in the public demonstration environment

The publicly accessible ARKA demonstration environment, including all clinical scenarios, patient records, identifiers, and images displayed therein, contains **synthetic, fictional data only** and is governed by ARKA-DEMO-001. The submission of PHI into the demonstration environment is prohibited, and conspicuous notices to that effect are presented to users. PHI received in violation of that prohibition shall be handled as an incident under ARKA-SEC-006 and deleted in accordance with ARKA-SEC-011.

3. PERMITTED AND REQUIRED USES AND DISCLOSURES

3.1 General rule

ARKA may use or disclose PHI **only** (a) as permitted or required by the applicable BAA; (b) as required by law within the meaning of 45 C.F.R. § 164.103; or (c) as required by the Secretary of the U.S. Department of Health and Human Services (the “**Secretary**”) to investigate or determine ARKA’s compliance with HIPAA. Any use or disclosure outside the foregoing is prohibited and shall be escalated to the Privacy Officer immediately upon discovery.

3.2 Specifically permitted activities

Subject to the terms of the applicable BAA, ARKA may:

- (a) use and disclose PHI as necessary to perform the services described in the underlying services agreement, including operation of clinical decision-support, eligibility, prior-authorization documentation, and analytics functions of the ARKA Platform;

- (b) use PHI for ARKA's proper management and administration and to carry out its legal responsibilities, and disclose PHI for such purposes where the disclosure is required by law or where ARKA obtains reasonable assurances, documented in writing, that the recipient will hold the PHI confidentially, use it only as required by law or for the purpose for which it was disclosed, and notify ARKA of any breach of confidentiality of which the recipient becomes aware;
- (c) provide data aggregation services relating to the health care operations of a Customer, where and to the extent permitted by the applicable BAA, in accordance with 45 C.F.R. § 164.504(e)(2)(i)(B); and
- (d) de-identify PHI in accordance with 45 C.F.R. § 164.514(a)–(c) and ARKA-PRIV-002, where and to the extent permitted by the applicable BAA, it being acknowledged that information de-identified in conformity with the foregoing is no longer PHI.

3.3 Prohibited uses and disclosures

Irrespective of any contrary instruction, ARKA shall not: (a) sell PHI within the meaning of 45 C.F.R. § 164.502(a)(5)(ii); (b) use or disclose PHI for marketing purposes except as permitted by 45 C.F.R. § 164.508(a)(3) pursuant to authorizations obtained by the Customer; (c) use or disclose genetic information for underwriting purposes in violation of 45 C.F.R. § 164.502(a)(5)(i); or (d) use or disclose PHI in any manner that would violate Subpart E of 45 C.F.R. Part 164 if done by the Customer, except as expressly permitted under Section 3.2(b)–(d) of this Policy.

3.4 Reproductive health care

ARKA shall not use or disclose PHI for the purpose of conducting a criminal, civil, or administrative investigation into, or imposing liability upon, any person for the mere act of seeking, obtaining, providing, or facilitating lawful reproductive health care, consistent with 45 C.F.R. § 164.502(a)(5)(iii), and shall obtain the attestations described at 45 C.F.R. § 164.509 where applicable before making any disclosure subject to that section.

4. MINIMUM NECESSARY STANDARD

When using, disclosing, or requesting PHI, ARKA shall make reasonable efforts to limit the PHI involved to the minimum necessary to accomplish the intended purpose, in accordance with 45 C.F.R. §§ 164.502(b) and 164.514(d). In furtherance of the foregoing:

- Access to production systems containing PHI is provisioned on a role-based, least-privilege basis under ARKA-SEC-003, and each role's permitted data scope is documented in the access matrix maintained by the Security Officer.
- The ARKA Platform ingests structured data elements through scoped FHIR R4 interfaces; integration scopes are limited to the resources and fields required for the contracted service, and scope expansions require change control under ARKA-SEC-010.
- Internal analytics, demonstrations, testing, and development use de-identified or synthetic data exclusively; production PHI shall not be copied into non-production environments (ARKA-SEC-010, § 6).
- The minimum-necessary standard does not apply to disclosures to or requests by a health care provider for treatment, disclosures to the individual, uses or disclosures pursuant to a valid authorization, disclosures to the Secretary, or uses or disclosures required by law.

5. INDIVIDUAL RIGHTS — BUSINESS ASSOCIATE SUPPORT OBLIGATIONS

The Privacy Rule grants individuals enumerated rights enforceable against covered entities. Where a BAA delegates any portion of those obligations to ARKA, or where PHI in ARKA's possession is implicated, ARKA shall perform as follows, in each case within the shorter of the period specified in the applicable BAA or the period set forth below:

Right	Citation	ARKA performance standard
Access / copies (incl. electronic copies of ePHI in a designated record set)	45 C.F.R. § 164.524	Make the PHI available to the Customer (or, if directed in writing by the Customer, to the individual) within ten (10) business days of the Customer's request, in the form and format requested where readily producible.
Amendment	45 C.F.R. § 164.526	Incorporate amendments to PHI in a designated record set as directed by the Customer within fifteen (15) business days of the Customer's request.
Accounting of disclosures	45 C.F.R. § 164.528	Maintain the disclosure log described in Section 6 and deliver the information required by § 164.528(b) within fifteen (15) business days of the Customer's request.
Restriction requests	45 C.F.R. § 164.522	Implement restrictions agreed to by the Customer, as communicated to ARKA in writing, within ten (10) business days.
Confidential communications	45 C.F.R. § 164.522(b)	Apply alternative-contact directives communicated by the Customer to any individual-facing communications generated by the ARKA Platform.

Requests received by ARKA directly from an individual shall be forwarded to the relevant Customer's designated privacy contact within five (5) business days of receipt, and ARKA shall not respond substantively to the individual except as the BAA directs.

6. ACCOUNTING LOG

The Privacy Officer shall maintain, for each Customer, a log of disclosures of PHI made by ARKA other than disclosures excepted by 45 C.F.R. § 164.528(a)(1), recording for each disclosure: the date; the name and, if known, address of the recipient; a brief description of the PHI disclosed; and a brief statement of the purpose. Log entries shall be retained for six (6) years and shall be generated, wherever practicable, from the immutable audit trail described in ARKA-SEC-005.

7. VERIFICATION OF IDENTITY AND AUTHORITY

Prior to any disclosure of PHI, the disclosing Workforce Member shall verify the identity and authority of the requestor in accordance with 45 C.F.R. § 164.514(h): for Customer personnel, by confirmation against the Customer's authorized-contact list; for public officials, by examination of credentials, agency identification, or a written statement of legal authority; and for individuals, by the authentication procedures of ARKA-SEC-003. Doubtful cases shall be escalated to the Privacy Officer before disclosure.

8. SAFEGUARDS; WORKFORCE CONFIDENTIALITY

ARKA shall maintain the administrative, physical, and technical safeguards described in the ARKA-SEC policy series to prevent any use or disclosure of PHI not permitted by this Policy. Each Workforce Member shall execute a confidentiality and acceptable-use undertaking on or before the first day of access to Company systems (ARKA-SEC-012, Appendix A), shall complete privacy and security training in accordance with ARKA-SEC-008, and shall report suspected impermissible uses or disclosures immediately, and in any event within twenty-four (24) hours of discovery, to the Privacy Officer.

9. MITIGATION; BREACH; COMPLAINTS

ARKA shall mitigate, to the extent practicable, any harmful effect known to ARKA of a use or disclosure of PHI in violation of this Policy or an applicable BAA. Suspected breaches of unsecured PHI shall be assessed, documented, and notified in strict accordance with ARKA-SEC-006 and 45 C.F.R. §§ 164.402, 164.410, and 164.412. Complaints concerning ARKA's privacy practices may be submitted to the Privacy Officer at privacy@getarka.health and shall be acknowledged within five (5) business days, investigated, and documented; the disposition of each complaint shall be retained for six (6) years. ARKA shall not retaliate against any person for filing a complaint and shall not require any individual to waive rights under HIPAA as a condition of service.

10. PREEMPTION AND MORE-STRINGENT STATE LAW

Where a state law relating to the privacy of health information is more stringent than HIPAA within the meaning of 45 C.F.R. § 160.202 — including, without limitation, state laws governing sensitive categories such as behavioral health, substance-use-disorder records subject to 42 C.F.R. Part 2, HIV status, and reproductive health, and state consumer-health-data statutes — ARKA shall comply with the more stringent standard. The Privacy Officer shall maintain a preemption matrix for each state in which a Customer deployment processes PHI and shall update the matrix before each new state deployment.

11. DOCUMENTATION

All documentation required by this Policy, including BAAs, authorizations, accounting logs, complaint files, training records, and policy versions, shall be maintained in written or electronic form for six (6) years from the later of the date of creation or the date last in effect, consistent with 45 C.F.R. § 164.530(j).

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026